

MARCO INTEGRATIVO QQM + PRAGMATIC

Indicadores CAPEC con Trazabilidad desde Objetivos Nacionales hasta Datos Técnicos

Kit QQM+PRAGMATIC CAPEC-ESP · Documento A · Versión 1.0 · Abril 2026

«Un indicador sin objetivo es un número buscando una historia. Un objetivo sin indicador es una aspiración buscando evidencia. QQM es el matrimonio de conveniencia entre ambos —y PRAGMATIC, el contrato prenupcial que lo hace sostenible.»

1. FUNDAMENTOS METODOLÓGICOS

1.1 La Metodología QQM (Goal-Question-Metric)

La metodología **QQM**, desarrollada por Victor Basili, Gianluigi Caldiera y H. Dieter Rombach en el Software Engineering Laboratory de la NASA (1994), propone un proceso de tres niveles para definir métricas con trazabilidad directa a objetivos organizacionales:

- Nivel Conceptual (Goal): Define QUÉ se quiere lograr y POR QUÉ
- Nivel Operacional (Question): Especifica CÓMO verificar el progreso hacia el objetivo
- Nivel Cuantitativo (Metric): Establece QUÉ se mide y CÓMO

La plantilla canónica del Goal QQM es:

Analizar <OBJETO>
Con el propósito de <PROPÓSITO>
Con respecto a <FOCO DE CALIDAD>
Desde la perspectiva de <PERSPECTIVA>
En el contexto de <ENTORNO>

1.2 El Marco PRAGMATIC

El marco **PRAGMATIC**, desarrollado por Hubbard & Seiersen (2016) y adaptado por el NIST para métricas de ciberseguridad, evalúa la calidad de cada métrica según nueve criterios:

Criterio	Descripción operacional
P — Predictivo	¿La métrica predice resultados futuros de seguridad?
R — Relevante	¿Es relevante para los objetivos de negocio y seguridad?
A — Accionable	¿Genera acciones concretas y decisiones?
G — Genuino	¿Mide lo que dice medir (sin proxy distorsionador)?
M — Significativo (Meaningful)	¿Es comprensible para la audiencia objetivo?
A — Preciso (Accurate)	¿Puede medirse con suficiente precisión?
T — Oportuno (Timely)	¿Está disponible cuando se necesita?
I — Independiente	¿Está libre de sesgos del medidor?
C — Rentable (Cost-effective)	¿El coste de medición es proporcional al valor?

Escala de puntuación: Cada criterio se puntúa de 1 (muy bajo) a 5 (muy alto). La puntuación PRAGMATIC total es la media aritmética de los 9 criterios (máximo 5,0).

1.3 La Integración GQM + PRAGMATIC para CAPEC

La integración de ambos marcos produce un sistema de **doble trazabilidad**:

OBJETIVO NACIONAL (Estrategia Nacional de Ciberseguridad)
↓ [GQM – Nivel Conceptual]
PREGUNTA DE INVESTIGACIÓN (¿Cómo verificamos el progreso?)
↓ [GQM – Nivel Operacional]
INDICADOR / MÉTRICA CAPEC (¿Qué medimos exactamente?)
↓ [PRAGMATIC – Evaluación de calidad]
PUNTUACIÓN PRAGMATIC (¿Vale la pena medirlo de esta forma?)
↓ [Decisión]
IMPLEMENTAR / REFORMULAR / DESCARTAR

2. OBJETIVOS NACIONALES DE REFERENCIA

Los indicadores CAPEC se anclan en los siguientes objetivos estratégicos nacionales e institucionales:

ID	Objetivo	Fuente	Relevancia CAPEC
ON-1	Reducir el impacto de los ciberataques en infraestructuras críticas	ENC España 2019–2025 / CNC 2025	CAPEC provee la taxonomía de patrones de ataque contra infraestructuras
ON-2	Elevar el nivel de madurez en ciberseguridad del sector público y privado	ENS RD 311/2022	IGM-CAPEC como índice de madurez nacional
ON-3	Garantizar el cumplimiento de NIS2 y la resiliencia de entidades esenciales e importantes	Transposición NIS2 (LCyGC 2025)	NIS2 Art. 21.2 exige gestión de amenazas; CAPEC la estructura
ON-4	Fortalecer la resiliencia del sector financiero ante riesgos TIC	DORA 2022/2554	Patrones CAPEC de alta severidad en sistemas financieros
ON-5	Desarrollar capacidades de inteligencia de amenazas compartida	INCIBE / CCN-CERT / Red de CSIRT	CAPEC es el vocabulario común para el intercambio de inteligencia
ON-6	Mitigar el riesgo de la cadena de suministro de software	NIS2 Art. 21.2.d / DORA Art. 28	Patrones CAPEC-437/538/695 para supply chain
ON-7	Preparar la infraestructura criptográfica ante la amenaza cuántica	NIST PQC / ENS actualización	Nuevas entradas CAPEC para HNDL
ON-8	Garantizar el uso seguro de la inteligencia artificial	NIST AI 100-2e2025 / ISO 42001	Patrones adversariales IA en CAPEC (pendientes de formalización)

3. ÁRBOL QQM COMPLETO POR DOMINIO CAPEC

DOMINIO 1: SOFTWARE

GOAL G-SW-1

Analizar: Los patrones de ataque sobre aplicaciones software, APIs y entornos web (CAPEC-63, 62, 86, 34, 22)

Con el propósito de: Reducir el tiempo de exposición a vulnerabilidades explotables mediante patrones conocidos

Con respecto a: Cobertura de controles preventivos y detectivos frente a los patrones de mayor likelihood

Desde la perspectiva de: CISOs, responsables de desarrollo seguro (DevSecOps), arquitectos de seguridad

En el contexto de: Organizaciones bajo NIS2 Art. 21.2.e y ENS, con aplicaciones web o APIs expuestas

Question Q-SW-1.1: ¿Qué porcentaje de los patrones CAPEC de dominio Software con Likelihood=High tienen al menos un control activo y verificado?

Metric M-SW-1.1: $\text{Cobertura_CAPEC_Software} = (\text{Patrones_SW_Likelihood_High_con_control} / \text{Total_Patrones_SW_Likelihood_High}) \times 100$

- Fuente de datos: Inventario de controles + CAPEC v3.9 Vista Software
- Frecuencia: Trimestral
- Umbral verde: $\geq 80\%$
- Umbral rojo: $< 50\%$

Question Q-SW-1.2: ¿En cuánto tiempo detecta la organización un ataque que sigue un patrón CAPEC de dominio Software?

Metric M-SW-1.2: $\text{MTTD_Software} = \text{Media}(\text{Tiempo_detección_incidentes_clasificados_dominio_SW})$ [en horas]

- Fuente de datos: SIEM / XDR con clasificación CAPEC
- Frecuencia: Mensual
- Umbral verde: < 4 horas
- Umbral rojo: > 24 horas

Question Q-SW-1.3: ¿Cuántas vulnerabilidades del inventario CVE están mapeadas a patrones CAPEC del dominio Software con Severity=High o Very High?

Metric M-SW-1.3: $\text{Exposición_CVE_CAPEC_SW} = \text{Recuento}(\text{CVE_activos_mapeados_CAPEC_SW_Severity_High})$

- Fuente de datos: Escáner de vulnerabilidades + base CVE con mapeo CAPEC
- Frecuencia: Semanal (integrado en ciclo de vulnerability management)
- Umbral verde: 0 CVE críticos sin plan de remediación en < 15 días

GOAL G-SW-2

Analizar: La efectividad del ciclo de desarrollo seguro (SSDLC/DevSecOps)
Con el propósito de: Detectar defectos explotables mediante patrones CAPEC antes de producción

Con respecto a: Tasa de escape de defectos a producción y coste de remediación

Desde la perspectiva de: DevSecOps Lead, CISO, Director de Ingeniería

En el contexto de: Entornos de desarrollo con CI/CD y despliegues continuos

Question Q-SW-2.1: ¿Qué porcentaje de las vulnerabilidades SAST/DAST mapeadas a patrones CAPEC se remedian antes del despliegue a producción?

Metric M-SW-2.1: $Tasa_Remediación_Pre_Prod = (Defectos_CAPEC_Remediados_Pre_Prod / Total_Defectos_CAPEC_Detectados_SAST_DAST) \times 100$

- Fuente de datos: Pipeline CI/CD con SAST/DAST integrado
- Frecuencia: Por sprint / release
- Umbral verde: $\geq 95\%$
- Umbral rojo: $< 80\%$

DOMINIO 2: INGENIERÍA SOCIAL

GOAL G-IS-1

Analizar: La susceptibilidad del personal a patrones de ingeniería social (CAPEC-98, 163, 195, 410, 383)

Con el propósito de: Reducir la tasa de éxito de ataques de phishing, spear phishing y vishing

Con respecto a: Tasa de respuesta del personal a simulaciones y tasa de incidentes reales

Desde la perspectiva de: CISO, RRHH, Consejo de Administración

En el contexto de: Entornos híbridos con amenaza creciente de IA generativa aplicada a ingeniería social

Question Q-IS-1.1: ¿Qué porcentaje del personal responde (hace clic / entrega credenciales) a simulaciones de phishing que replican patrones CAPEC-98 y CAPEC-163?

Metric M-IS-1.1: $Tasa_Click_Phishing = (Empleados_que_hicieron_clic / Total_Empleados_Objetivo) \times 100$

- Fuente de datos: Plataforma de simulación de phishing (KnowBe4, Proofpoint, etc.)
- Frecuencia: Mensual (mínimo trimestral)
- Umbral verde: $< 5\%$
- Umbral rojo: $> 20\%$

Question Q-IS-1.2: ¿Qué porcentaje de incidentes de ingeniería social reales son clasificados según patrones CAPEC en el análisis post-incidente?

Metric M-IS-1.2: $Cobertura_Clasificación_IS = (Incidentes_IS_con_CAPEC_ID / Total_Incidentes_IS_confirmados) \times 100$

- Fuente de datos: Sistema de gestión de incidentes (ITSM / SOAR)
- Frecuencia: Mensual
- Umbral verde: $\geq 90\%$

Question Q-IS-1.3: ¿Cuánto tiempo transcurre desde que el usuario reporta una tentativa de ingeniería social hasta que se toman acciones de contención?

Metric M-IS-1.3: $MTTC_Social_Engineering = Media(T_contención - T_reporte_usuario)$ [en minutos]

- Fuente de datos: Plataforma SOAR + registros de reporte de usuarios
- Frecuencia: Por incidente; revisión mensual
- Umbral verde: < 30 minutos
- Umbral rojo: > 4 horas

DOMINIO 3: CADENA DE SUMINISTRO DE SOFTWARE

GOAL G-SC-1

Analizar: El riesgo de los patrones de ataque a la cadena de suministro de software (CAPEC-437, 538, 695, 186, 670)

Con el propósito de: Detectar compromisos en dependencias de terceros antes de que lleguen a producción

Con respecto a: Cobertura del inventario de software (SBOM) y tasa de vulnerabilidades supply chain detectadas

Desde la perspectiva de: CISO, DevSecOps Lead, Director de Compras TIC

En el contexto de: NIS2 Art. 21.2.d y DORA Art. 28; ecosistemas con alta densidad de software de código abierto

Question Q-SC-1.1: ¿Qué porcentaje de los componentes de software de terceros en producción tienen un SBOM generado, actualizado y verificado?

Metric M-SC-1.1: $Cobertura_SBOM = (Componentes_en_SBOM_actualizado / Total_Componentes_SW_Terceros_Producción) \times 100$

- Fuente de datos: Herramienta SCA (Snyk, Dependabot, OWASP Dependency-Check)
- Frecuencia: Continua (integrada en CI/CD); reporte semanal
- Umbral verde: 100%
- Umbral rojo: $< 70\%$

Question Q-SC-1.2: ¿Cuántas vulnerabilidades de tipo supply chain (mapeadas a CAPEC-437/538/695) se han detectado antes de llegar a producción vs. después?

Metric M-SC-1.2: $Ratio_Detección_Pre_Post_SupplyChain = Detecciones_Pre_Prod_SC / (Detecciones_Pre_Prod_SC + Incidentes_Post_Prod_SC)$

- Fuente de datos: SCA pipeline + gestión de incidentes
- Frecuencia: Mensual
- Umbral verde: $\geq 0,90$ ($\geq 90\%$ detectados antes de producción)

Question Q-SC-1.3: ¿Cuál es el tiempo medio desde la publicación de una vulnerabilidad supply chain hasta su remediación en entornos productivos?

Metric M-SC-1.3: $MTTR_SupplyChain = Media(T_remediación - T_publicación_CVE)$ [en días]
para vulnerabilidades CAPEC-SC

- Fuente de datos: Base NVD/CVE + registros de parching + SBOM
- Frecuencia: Por vulnerabilidad; agregado mensual
- Umbral verde (CRÍTICO): < 7 días
- Umbral verde (ALTO): < 30 días
- Umbral rojo: > 90 días

DOMINIO 4: COMUNICACIONES Y RED

GOAL G-NET-1

Analizar: La exposición a patrones de ataque sobre protocolos y comunicaciones de red (CAPEC-21, 194, 610, 216, 117)

Con el propósito de: Reducir la superficie de ataque en el plano de comunicaciones

Con respecto a: Cobertura de controles criptográficos y de integridad de protocolo

Desde la perspectiva de: Arquitecto de red, CISO, equipo de SOC

En el contexto de: Entornos híbridos, multi-cloud y Zero Trust en implementación

Question Q-NET-1.1: ¿Qué porcentaje del tráfico de red interno y externo está protegido con protocolos seguros vigentes (TLS 1.3, mTLS, IPSec)?

Metric M-NET-1.1: $Cobertura_Tráfico_Cifrado = (Volumen_tráfico_con_protocolo_vigente / Volumen_total_tráfico) \times 100$

- Fuente de datos: Herramientas de visibilidad de red (NDR); certificados SSL/TLS del inventario
- Frecuencia: Mensual
- Umbral verde: $\geq 99\%$ (tráfico sensible); $\geq 95\%$ (tráfico general)

Question Q-NET-1.2: ¿Cuántos certificados TLS en producción tienen algoritmos vulnerables (RSA < 2048 bits, SHA-1, algoritmos pre-cuánticos) que los hacen susceptibles a patrones CAPEC de interceptación?

Metric M-NET-1.2: $Certificados_Algoritmo_Vulnerable = Recuento(Certificados_activos_con_algoritmo_débil_o_expirado)$

- Fuente de datos: Escáner de certificados (Qualys SSL Labs, Censys, inventario interno)
- Frecuencia: Semanal
- Umbral verde: 0
- Umbral rojo: > 5

DOMINIO 5: HARDWARE Y FIRMWARE

GOAL G-HW-1

Analizar: La exposición a patrones de ataque sobre firmware, BIOS/UEFI y hardware (CAPEC-187, 440, 624, 169)

Con el propósito de: Detectar compromisos de firmware antes de que persistan en el ciclo de vida del equipo

Con respecto a: Porcentaje de dispositivos con firmware verificado y actualizado

Desde la perspectiva de: Equipo de operaciones TI, arquitecto de seguridad, equipo OT

En el contexto de: Infraestructuras críticas y entornos industriales con equipos de larga vida útil

Question Q-HW-1.1: ¿Qué porcentaje de los dispositivos críticos (servidores, equipos de red, endpoints privilegiados) tienen firmware verificado criptográficamente y actualizado?

Metric M-HW-1.1: $\text{Cobertura_Firmware_Verificado} = (\text{Dispositivos_firmware_verificado_y_actual} / \text{Total_dispositivos_críticos}) \times 100$

- Fuente de datos: MDM / inventario de activos + registros de actualización de firmware
- Frecuencia: Mensual
- Umbral verde: $\geq 95\%$
- Umbral rojo: $< 75\%$

DOMINIO 6: ICS / OT / ENTORNOS INDUSTRIALES

GOAL G-OT-1

Analizar: La exposición a patrones de ataque sobre sistemas de control industrial (CAPEC-703 y subpatrones)

Con el propósito de: Detectar y contener ataques que puedan causar impacto físico o interrupción de servicio crítico

Con respecto a: Cobertura de controles de segmentación, detección y respuesta en entornos OT

Desde la perspectiva de: CISO, Director de Operaciones, Responsable de Seguridad OT

En el contexto de: Operadores de infraestructuras críticas (energía, agua, transporte) bajo ENS y NIS2

Question Q-OT-1.1: ¿Qué porcentaje de los activos OT/ICS críticos están debidamente segmentados del entorno IT mediante zonas de seguridad (Purdue Model o IEC 62443)?

Metric M-OT-1.1: $\text{Segmentación_OT} = (\text{Activos_OT_en_zona_segmentada_verificada} / \text{Total_Activos_OT_Críticos}) \times 100$

- Fuente de datos: Inventario OT + diagramas de red + auditoría de segmentación
- Frecuencia: Trimestral
- Umbral verde: 100%
- Umbral rojo: $< 85\%$

DOMINIO 7: IA ADVERSARIAL (EMERGENTE)

GOAL G-AI-1

Analizar: La exposición a ataques adversariales sobre sistemas de IA/ML en producción (NIST AI 100-2e2025 / CAPEC futuro)

Con el propósito de: Detectar intentos de manipulación, extracción o envenenamiento de modelos de IA

Con respecto a: Cobertura de controles de seguridad del ciclo de vida de modelos de IA Desde la perspectiva de: CISO, Chief AI Officer (CAIO), equipo de MLOps

En el contexto de: Organizaciones con sistemas de IA en producción bajo ISO 42001 y futura regulación EU AI Act

Question Q-AI-1.1: ¿Qué porcentaje de los modelos de IA en producción tienen controles de detección de ataques adversariales (evasion, poisoning, extraction) implementados y probados?

Metric M-AI-1.1: Cobertura_Controles_AI_Adversarial =

$(\text{Modelos_IA_prod_con_controles_adversariales} / \text{Total_modelos_IA_prod}) \times 100$

- Fuente de datos: Registro de modelos (model registry) + resultados de red teaming de IA
- Frecuencia: Por release de modelo; revisión trimestral
- Umbral verde: $\geq 80\%$
- Umbral rojo: $< 40\%$

Question Q-AI-1.2: ¿Existe un proceso formal de Prompt Injection testing para los LLMs o asistentes de IA desplegados en producción?

Metric M-AI-1.2: Madurez_Prompt_Injection_Testing — Escala ordinal:

- 0: Sin proceso
- 1: Pruebas ad hoc
- 2: Proceso documentado sin automatización
- 3: Testing automatizado en pipeline
- 4: Red teaming adversarial periódico con cobertura $\geq 80\%$ de casos

DOMINIO 8: CRIPTOGRAFÍA POST-CUÁNTICA

GOAL G-PQC-1

Analizar: El nivel de preparación criptográfica ante la amenaza de computación cuántica (HNDL / CRQC)

Con el propósito de: Establecer un baseline de cryptoagility y planificar la migración a algoritmos NIST PQC

Con respecto a: Inventario criptográfico, exposición HNDL y progreso del plan de migración

Desde la perspectiva de: CISO, Arquitecto de Seguridad, Director de Infraestructura

En el contexto de: Todo tipo de organización que maneje datos con vida útil > 5 años

Question Q-PQC-1.1: ¿Qué porcentaje del inventario criptográfico total ha sido catalogado y evaluado respecto a su vulnerabilidad ante computación cuántica?

Metric M-PQC-1.1: Cobertura_Crypto_Inventory = $(\text{Algoritmos_catalogados_y_evaluados} / \text{Total_algoritmos_en_uso_estimado}) \times 100$

- Fuente de datos: Escaneo criptográfico (OpenSSL, herramientas de crypto-discovery)
- Frecuencia: Semestral
- Umbral verde: $\geq 90\%$
- Umbral rojo: $< 50\%$

Question Q-PQC-1.2: ¿Qué porcentaje de los sistemas que manejan datos con requisito de confidencialidad > 10 años han iniciado la migración a algoritmos NIST PQC (ML-KEM, ML-DSA, SLH-DSA)?

Metric M-PQC-1.2: $\text{Progreso_Migración_PQC} = \left(\frac{\text{Sistemas_alto_impacto_migrados_o_en_migración}}{\text{Total_sistemas_alto_impacto_cripto}} \right) \times 100$

- Fuente de datos: Registro del programa de migración PQC
- Frecuencia: Trimestral
- Umbral verde (2026): $\geq 20\%$ (fase inicial de migración)
- Umbral verde (2028): $\geq 70\%$
- Umbral rojo (2026): 0% (sin inicio)

4. INDICADORES ESTRATÉGICOS TRANSVERSALES

GOAL G-GOV-1 — Gobernanza y Reporte al Consejo

Analizar: La calidad del reporte de métricas CAPEC al órgano de gobierno
Con el propósito de: Asegurar que el Consejo toma decisiones informadas sobre el riesgo cibernético
Con respecto a: Frecuencia, cobertura y accionabilidad del reporte de ciberseguridad
Desde la perspectiva de: Consejo de Administración, Comité de Auditoría, Regulador
En el contexto de: NIS2 Art. 20, DORA Art. 5, ENS Principio 3

Metric M-GOV-1.1: $\text{Frecuencia_Reporte_Consejo}$ — Escala ordinal: 1 (nunca) – 5 (mensual)

Metric M-GOV-1.2: IGM-CAPEC_Global — Índice compuesto 0–5 (calculado en Documento E)

Metric M-GOV-1.3: $\text{Cobertura_KRI_CAPEC} = \frac{\text{Número de Key Risk Indicators basados en CAPEC reportados}}{15}$ (KRIs objetivo del marco)

GOAL G-RES-1 — Resiliencia y Continuidad

Analizar: La capacidad de la organización para resistir y recuperarse de incidentes basados en patrones CAPEC de alta severidad
Con el propósito de: Garantizar la continuidad del negocio ante los escenarios de ataque más probables del sector
Con respecto a: RTO/RPO definidos y probados por tipo de patrón de ataque
Desde la perspectiva de: CRO, CISO, Director de Operaciones, Regulador
En el contexto de: NIS2 Art. 21.2.c, DORA Art. 11, ENS M.op.cont.1

Metric M-RES-1.1: $\text{RTO_por_Patrón_CAPEC} = \text{Tiempo de recuperación real en ejercicios para cada escenario CAPEC de alta severidad [en horas]}$

Metric M-RES-1.2: $\text{Cobertura_Escenarios_BCP} = \left(\frac{\text{Patrones_CAPEC_alta_severidad_en_BCP}}{\text{Total_patrones_alta_severidad_sector}} \right) \times 100$

Metric M-RES-1.3: $\text{Ratio_Ejercicios_por_Año} = \frac{\text{Número de tabletop exercises con escenarios CAPEC}}{4}$ (objetivo trimestral)

5. TABLA RESUMEN DE INDICADORES POR DOMINIO

ID Métrica	Dominio	Objetivo Nacional	Pregunta GQM	Tipo	Frecuencia	Umbral Verde
M-SW-1.1	Software	ON-2, ON-3	Q-SW-1.1	% cobertura	Trimestral	≥ 80%
M-SW-1.2	Software	ON-2	Q-SW-1.2	Horas (MTTD)	Mensual	< 4h
M-SW-1.3	Software	ON-3	Q-SW-1.3	Recuento CVE	Semanal	0 sin plan
M-SW-2.1	Software/ DevSec	ON-3	Q-SW-2.1	% remediación	Por sprint	≥ 95%
M-IS-1.1	Ing. Social	ON-2	Q-IS-1.1	% tasa clic	Mensual	< 5%
M-IS-1.2	Ing. Social	ON-5	Q-IS-1.2	% clasificación	Mensual	≥ 90%
M-IS-1.3	Ing. Social	ON-2	Q-IS-1.3	Minutos (MTTC)	Por incidente	< 30 min
M-SC-1.1	Supply Chain	ON-6	Q-SC-1.1	% SBOM	Continua	100%
M-SC-1.2	Supply Chain	ON-6	Q-SC-1.2	Ratio detección	Mensual	≥ 0,90
M-SC-1.3	Supply Chain	ON-6	Q-SC-1.3	Días (MTTR)	Por vuln.	< 7 días
M-NET-1.1	Comunicaciones	ON-2, ON-7	Q-NET-1.1	% tráfico	Mensual	≥ 99%
M-NET-1.2	Comunicaciones	ON-7	Q-NET-1.2	Recuento certic.	Semanal	0
M-HW-1.1	Hardware	ON-2	Q-HW-1.1	% dispositivos	Mensual	≥ 95%
M-OT-1.1	ICS/OT	ON-1, ON-3	Q-OT-1.1	% segmentación	Trimestral	100%
M-AI-1.1	IA Adversarial	ON-8	Q-AI-1.1	% modelos	Por release	≥ 80%
M-AI-1.2	IA Adversarial	ON-8	Q-AI-1.2	Escala 0-4	Trimestral	≥ 3
M-PQC-1.1	Post-Quantum	ON-7	Q-PQC-1.1	% inventario	Semestral	≥ 90%
M-PQC-1.2	Post-Quantum	ON-7	Q-PQC-1.2	% migración	Trimestral	≥ 20% (2026)
M-GOV-1.1	Gobernanza	ON-2, ON-3	Gobernanza	Escala 1-5	—	5
M-GOV-1.2	Transversal	Todos	IGM-CAPEC	Índice 0-5	Trimestral	≥ 3,0
M-GOV-1.3	Gobernanza	ON-2	KRI CAPEC	% cobertura KRI	Trimestral	≥ 80%
M-RES-1.1	Resiliencia	ON-2, ON-3	RTO patrón	Horas	Por ejercicio	Por BIA

M-RES-1.2	Resiliencia	ON-1, ON-3	BCP CAPEC	% cobertura	Semestral	≥ 90%
M-RES-1.3	Resiliencia	ON-2	Ejercicios	Ratio 0-1	Anual	1,0

Kit GQM+PRAGMATIC CAPEC-ESP · Documento A: Marco Integrativo · Versión 1.0 · Abril 2026

Basado en: MITRE CAPEC v3.9 · GQM (Basili et al., 1994) · PRAGMATIC (Hubbard & Seiersen, 2016) · ENC España 2019-2025 · NIS2 2022/2555 · ENS RD 311/2022 · NIST AI 100-2e2025 · NIST FIPS 203/204/205